Custodia: Aplicación de Escritorio para la Custodia Cifrada de Archivos con Control de Acceso Real sobre Windows.

Manual del sistema

Dioyanny Y. Aranguren S. y Paula A. Quintana B.

Programa de Ingeniería de Sistemas, Universidad Cooperativa de Colombia, Campus Villavicencio

Electiva Específica

Docente: Carlos Torres Londoño

Villavicencio, Meta

10 de noviembre de 2026

Tabla de contenido

Introducción....5
Objetivo del manual....5
Objetivo del sistema....5
Usuarios a quien va dirigido....5
Descripción de la aplicación....6
Requerimientos de hardware y software....7
Instalación....8
Paso 1. Preparar el equipo....8
Paso 2. Obtener la aplicación....8
Paso 3. Primer arranque....9
Paso 4. Configurar las variables de entorno....9
Paso 5. Respaldar la clave maestra....10
Paso 6. Verificar la instalación....11
Actualización del sistema....11
Administración del sistema....12
Casos de uso....12
Modelo de datos....20
Seguridad y control de operación....23
Recomendaciones de operación....24
Referencias....26

Lista de tablas

Tabla 1. Módulos de Custodia....6
Tabla 2. Tecnologías del sistema....7
Tabla 3. Requerimientos del equipo....7
Tabla 4. Variables de configuración....9
Tabla 5. Descripción de los actores....13
Tabla 6. Caso de uso iniciar sesión....13
Tabla 7. Caso de uso explorar y abrir archivos....14
Tabla 8. Caso de uso añadir archivos y carpetas....14
Tabla 9. Caso de uso renombrar o eliminar....15

Tabla 10. Caso de uso guardar una copia.....15
Tabla 11. Caso de uso gestionar permisos.....16
Tabla 12. Caso de uso activar verificación en dos pasos.....16
Tabla 13. Caso de uso cambiar contraseña.....17
Tabla 14. Caso de uso bloquear y desbloquear la sesión.....17
Tabla 15. Caso de uso administrar cuentas y grupos.....18
Tabla 16. Caso de uso consultar y verificar la bitácora.....18
Tabla 17. Caso de uso respaldar y restaurar la clave maestra.....19
Tabla 18. Caso de uso crear clave de recuperación y recuperar una cuenta.....20
Tabla 19. Diccionario de datos de la bitácora (tabla eventos).....21
Tabla 20. Archivos de datos del sistema.....22
Tabla 21. Formato de un archivo cifrado.....22
Tabla 22. Errores del sistema.....24

Lista de figuras

Figura 1. Diagrama de casos de uso..... 12
Figura 2. Diagrama de clases..... 21

Introducción

Custodia es una aplicación de escritorio para Windows que guarda archivos de forma segura. Cifra en reposo el contenido de cada archivo con AES-256-GCM y no decide por sí misma quién puede abrirlo: cada persona es una cuenta local real de Windows, cada carpeta tiene permisos NTFS reales y cada operación se ejecuta con la identidad del usuario, de modo que es el sistema operativo el que la autoriza o la deniega. Además exige un segundo factor de autenticación (TOTP) para entrar y para cada operación sensible, y registra cada intento en una bitácora de auditoría encadenada.

Este manual está dirigido a quien instala, configura y mantiene el sistema. Describe sus componentes, los requerimientos para ponerlo en funcionamiento, el procedimiento de instalación en el equipo, los casos de uso que rigen su comportamiento, el modelo de datos y las medidas de seguridad y control de operación.

Objetivo del manual

Documentar la arquitectura, la instalación, la administración y la seguridad de Custodia, presentando las recomendaciones y los pasos necesarios para implementar, operar y mantener el sistema.

Objetivo del sistema

Desarrollar una aplicación de escritorio para Windows que proteja la confidencialidad de los archivos que gestiona mediante cifrado en reposo con AES-256-GCM, delegando la autorización de cada operación al sistema operativo y registrando cada acceso en una bitácora de auditoría.

Usuarios a quien va dirigido

Este manual va dirigido al administrador técnico del sistema, es decir, la persona encargada de instalar, configurar, actualizar y respaldar Custodia en el equipo, y de administrar las cuentas de los usuarios. Requiere conocimientos básicos de administración de Windows (cuentas locales, permisos NTFS y consola) y, para compilar el ejecutable o ejecutar las pruebas, de Python.

Descripción de la aplicación

Custodia está construida en capas. La capa de interfaz es una ventana nativa hecha con PySide6 y Qt Quick (QML): solo dibuja y avisa lo que la persona hace, sin tomar decisiones de seguridad. La capa de sesión, la clase `Sesion`, es la frontera con el núcleo y el único lugar del programa que adopta la identidad del usuario y la revierte. El núcleo, escrito en Python, contiene el cifrado, el confinamiento de rutas, el segundo factor, la bitácora y la administración de cuentas y permisos. Por debajo está Windows, que valida las contraseñas, guarda las cuentas, evalúa los permisos NTFS y protege la clave maestra con DPAPI.

El principio central es que la aplicación no evalúa permisos: no existe ninguna condición en el código que decida si un usuario puede leer un archivo. Custodia obtiene un token del usuario con `LogonUser`, lo adopta con `ImpersonateLoggedOnUser`, intenta la operación y, si Windows la rechaza, traduce el rechazo a un mensaje. Funcionalmente, el sistema se organiza en los módulos de la Tabla 1, y la Tabla 2 resume las tecnologías utilizadas.

Tabla 1
Módulos de Custodia

Módulo	Funciones
Archivos	Explorar, buscar, abrir, añadir, renombrar, mover, copiar y eliminar archivos y carpetas dentro del almacén, siempre con la identidad del usuario.
Permisos	Consultar los permisos efectivos de cada elemento y conceder o quitar permisos NTFS a cuentas y grupos.
Cifrado	Cifrado AES-256-GCM de cada archivo con la clave maestra protegida por DPAPI y, de forma opcional, cifrado por usuario con clave de recuperación.
Autenticación	Inicio de sesión con la contraseña de Windows, bloqueo por intentos fallidos, verificación en dos pasos (TOTP) y bloqueo por inactividad.
Administración	Cuentas y grupos locales, contraseñas temporales, restablecimiento del segundo factor, respaldo y restauración de la clave maestra.
Trazabilidad	Bitácora de auditoría encadenada con SHA-256, con anclas en el Visor de eventos de Windows y verificación de integridad.
Control de copias	Motivo obligatorio y límite de 20 copias legibles cada 10 minutos por usuario.

Nota. Elaboración propia.

Tabla 2
Tecnologías del sistema

Componente	Tecnología	Función
Lenguaje	Python 3.12 o superior	Núcleo e interfaz.
Interfaz	PySide6 6.8 y Qt Quick (QML)	Ventana nativa de escritorio, sin navegador ni servidor local.
API de Windows	pywin32	LogonUser, suplantación, cuentas y grupos locales, ACL de NTFS, DPAPI, WMI y Visor de eventos.
Criptografía	cryptography 44 (OpenSSL)	AES-256-GCM, RSA-OAEP y scrypt.
Bitácora	SQLite	Base de datos de auditoría, sin servidor ni credenciales.
Segundo factor	TOTP (RFC 6238) y segno	Códigos de 6 dígitos y código QR generado en el equipo.
Pruebas	pytest y pytest-cov	382 pruebas sobre Windows real y medición de cobertura.
Empaquetado	PyInstaller 6.11	Ejecutable único `Custodia.exe` con manifiesto que pide elevación.

Nota. Elaboración propia a partir del código fuente del proyecto (Aranguren y Quintana, 2026a).

Requerimientos de hardware y software

Custodia se instala en el equipo Windows donde se guardarán los archivos, y las personas la usan sentadas en ese mismo equipo. No necesita conexión a internet ni servidor. La Tabla 3 presenta los requerimientos.

Tabla 3
Requerimientos del equipo

Elemento	Requerimiento mínimo
Sistema operativo	Windows 10 u 11 de 64 bits. Las ediciones Pro, Enterprise o Education permiten activar BitLocker; en Home depende de que el equipo admita el cifrado del dispositivo.
Sistema de archivos	Unidad con NTFS para el almacén (`C:\ProgramData\Custodia`).
Procesador y memoria	Los que exige la versión de Windows instalada; la aplicación no impone un mínimo propio.
Disco	Unos 200 MB para el ejecutable más el espacio de los archivos que se vayan a guardar.
Cuenta	Una cuenta con privilegios de administrador de Windows para instalar y abrir la aplicación.
Teléfono	Una aplicación de autenticación (Google Authenticator, Microsoft Authenticator, Authy o similar) para cada persona que active la verificación en dos pasos.

Elemento	Requerimiento mínimo
Recomendado	Chip TPM y BitLocker activo en la unidad del almacén; una memoria USB para el respaldo de la clave.
Equipo de compilación	Solo para compilar o ejecutar las pruebas: Python 3.12 o superior y las dependencias de `requirements.txt`.

Nota. Elaboración propia.

Instalación

Custodia se puede instalar de dos formas: con el ejecutable único `Custodia.exe`, que no requiere Python, o desde el código fuente. En ambos casos la aplicación debe ejecutarse como administrador, porque crea cuentas locales, escribe permisos NTFS y usa DPAPI. Los comandos se presentan como referencia y se ejecutan en una consola abierta como administrador.

Paso 1. Preparar el equipo

Se verifica que el equipo tenga Windows 10 u 11 actualizado y una cuenta con privilegios de administrador. Antes de guardar archivos se recomienda activar BitLocker en la unidad C:, desde Configuración > Privacidad y seguridad > Cifrado del dispositivo, o desde Panel de control > Cifrado de unidad BitLocker en las ediciones Pro. El estado se comprueba con:

```
manage-bde -status C:
```

Paso 2. Obtener la aplicación

Con el ejecutable, basta copiar `Custodia.exe` en una carpeta del equipo, por ejemplo `C:\Program Files\Custodia`. Desde el código fuente, se clona el repositorio y se crea un entorno virtual con las dependencias:

```
git clone https://github.com/yanni2327/custodia.git
cd custodia
py -m venv .venv
.venv\Scripts\activate.bat
pip install -r requirements.txt
```

Paso 3. Primer arranque

Al abrir `Custodia.exe`, Windows pide permiso para ejecutarlo como administrador, porque el ejecutable lleva un manifiesto `requireAdministrator`. Desde el código fuente se ejecuta `python scripts\custodia_gui.py` en la consola elevada. En un equipo donde nunca se ha usado, la aplicación muestra el aviso «Primer arranque de Custodia» y, al aceptar con «Sí, preparar», realiza lo siguiente:

1. Crea los grupos locales `Custodia_Usuarios` y `Custodia_Administradores`.
2. Crea la clave maestra AES-256 y la guarda protegida con DPAPI en `master.key`, con una ACL que solo permite a Administradores y SYSTEM.
3. Crea el almacén en `C:\ProgramData\Custodia\storage`: la raíz solo se puede atravesar y la carpeta `Compartida` se concede al grupo de usuarios.
4. Crea la bitácora de auditoría `audit.db`.
5. Pide los datos de la primera cuenta administradora.

Desde el código fuente, el mismo resultado se obtiene con `python scripts\bootstrap.py --admin <usuario>`. Cada arranque del ejecutable tarda unos segundos, porque se descomprime en una carpeta temporal.

Paso 4. Configurar las variables de entorno

Custodia funciona con los valores por defecto, pero su comportamiento se ajusta con variables de entorno del sistema, que se definen como administrador con `setx /M` o desde Propiedades del sistema > Variables de entorno, y rigen desde el siguiente arranque. La Tabla 4 lista las principales.

Tabla 4
Variables de configuración

Variable	Qué configura	Por defecto
CUSTODIA_STORAGE_ROOT	Carpeta raíz del almacén.	C:\ProgramData\Custodia\storage
CUSTODIA_EXIGIR_BITLOCKER	Impide la entrada si la unidad del almacén no tiene BitLocker activo (C15).	0

Variable	Qué configura	Por defecto
CUSTODIA_CIFRADO_POR_USUARIO	Activa el cifrado por usuario (C20); solo rige si existe la clave de recuperación.	0
CUSTODIA_ANCLAR_BITACORA	Escribe anclas de la bitácora en el Visor de eventos (C16).	1
CUSTODIA_BLOQUEO_INACTIVIDAD_MIN	Minutos sin uso antes de bloquear la pantalla (0 lo desactiva).	5
CUSTODIA_SESSION_IDLE_MINUTES	Minutos bloqueada antes de cerrar la sesión.	30
CUSTODIA_MAX_INTENTOS, _VENTANA_INTENTOS_MIN, _BLOQUEO_MIN	Intentos fallidos permitidos, ventana en que se cuentan y duración del bloqueo.	5, 10 y 15
CUSTODIA_MAX_DESCARGAS, _VENTANA_DESCARGAS_MIN	Copias legibles permitidas y ventana en que se cuentan.	20 y 10
CUSTODIA_MAX_FILE_BYTES	Tamaño máximo de un archivo.	64 MB
CUSTODIA_RETENCION_COPIA_CLAVE_DIAS	Días que se conserva la clave anterior tras restaurar un respaldo.	30
CUSTODIA_APP_GROUP, CUSTODIA_ADMIN_GROUP	Nombres de los grupos locales de la aplicación.	Custodia_Usuarios y Custodia_Administradores

Nota. Elaboración propia a partir del módulo `config.py` (Aranguren y Quintana, 2026a).

Por ejemplo, para exigir BitLocker una vez activado:

```
setx /M CUSTODIA_EXIGIR_BITLOCKER 1
```

Paso 5. Respaldar la clave maestra

La clave maestra protegida con DPAPI solo se abre en el equipo que la creó; si se pierde o se daña, los archivos cifrados no se pueden recuperar. Por eso, apenas termina la instalación, el administrador entra a la aplicación, abre su perfil > «Respaldo de la clave» > «Exportar respaldo», escribe una contraseña de recuperación de al menos 12 caracteres, guarda el archivo `.custodiakey` en una memoria USB y confirma con su código TOTP. El archivo y su contraseña se guardan en lugares distintos.

Si se va a usar el cifrado por usuario, en la misma hoja se elige «Crear clave de recuperación», con una contraseña distinta, y se guarda el archivo `.custodiarec` en una USB

que conserva el dueño del computador. Después se define `CUSTODIA_CIFRADO_POR_USUARIO=1`.

Paso 6. Verificar la instalación

Se abre la aplicación, se ingresa con la cuenta administradora y se activa la verificación en dos pasos desde el perfil. Desde una consola como administrador se comprueba, sin pasar por Custodia, que los controles son reales:

```
net localgroup Custodia_Usuarios
icacls C:\ProgramData\Custodia\storage
icacls C:\ProgramData\Custodia\master.key
```

La raíz del almacén debe permitir a los usuarios solo atravesarla, y `master.key` debe estar limitado a Administradores y SYSTEM. Al abrir cualquier archivo del almacén con un editor de texto debe verse la marca `CUSTODIA` seguida de contenido ilegible. Desde el código fuente, además, se ejecutan las pruebas:

```
pytest
pytest --cov=custodia.core --cov-report=term-missing
```

Actualización del sistema

Para publicar una versión nueva se actualiza el código, se ejecutan las pruebas y se reconstruye el ejecutable desde una consola sin elevar, como recomienda PyInstaller. El resultado queda en `dist\Custodia.exe` y reemplaza al anterior. Los datos no cambian: el almacén, la clave, la bitácora y los secretos están en `C:\ProgramData\Custodia` y la aplicación los reutiliza; una bitácora anterior a la versión con encadenamiento se encadena sola al abrirla.

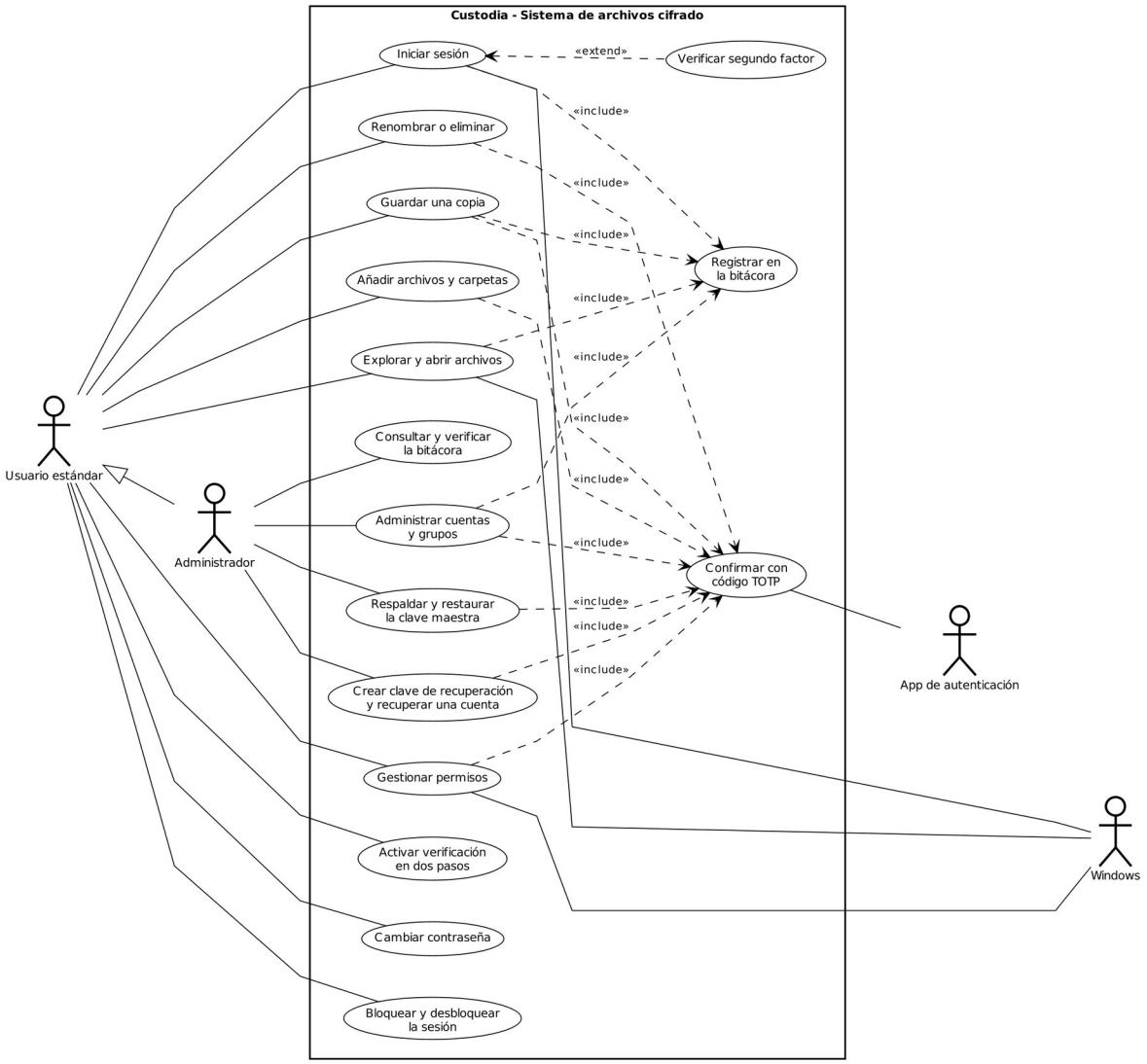
```
git pull
.venv\Scripts\python.exe -m pytest
.venv\Scripts\python.exe -m PyInstaller custodia.spec --noconfirm
```

Administración del sistema

Casos de uso

La Figura 1 presenta el diagrama general de casos de uso de Custodia y la Tabla 5 describe sus actores.

Figura 1
Diagrama de casos de uso



Nota. Elaboración propia.

Tabla 5
Descripción de los actores

Actor	Descripción
Usuario estándar	Persona con una cuenta en el grupo `Custodia_Usuarios`. Trabaja con los archivos de su espacio personal y de la carpeta compartida de su grupo.
Administrador	Hereda las funciones del usuario estándar y, además, administra cuentas y grupos, consulta y verifica la bitácora, respalda y restaura la clave maestra y crea la clave de recuperación. Pertenece a `Custodia_Administradores`.
Windows	Sistema externo que valida las contraseñas (SAM), autoriza cada operación según los permisos NTFS y protege la clave maestra y los secretos con DPAPI.
App de autenticación	Aplicación del teléfono que genera los códigos TOTP de seis dígitos.

Nota. Descripción de los actores. Elaboración propia.

Las tablas siguientes especifican los casos de uso principales. Los errores que se mencionan en los flujos alternativos se explican en la sección de seguridad y control de operación.

Tabla 6
Caso de uso iniciar sesión

Elemento	Descripción
Caso de uso	Iniciar sesión
Identificador	CU-01
Descripción	Permite el ingreso de una persona con su usuario y contraseña de Windows y, si la cuenta lo tiene activo, con su segundo factor.
Actor principal	Usuario estándar
Actor secundario	Administrador, Windows
Precondiciones	• La persona tiene una cuenta activa en el grupo `Custodia_Usuarios`.
Flujo principal	1. El usuario abre Custodia. 2. El sistema muestra la pantalla de inicio de sesión. 3. El usuario escribe su usuario y su contraseña y pulsa «Entrar». 4. El sistema comprueba que la cuenta no esté bloqueada y Windows valida la contraseña con `LogonUser`. 5. El sistema comprueba que la cuenta pertenezca a Custodia. 6. Si la cuenta tiene segundo factor, el sistema pide el código de seis dígitos y el usuario lo escribe. 7. El sistema crea la sesión con el token de Windows y muestra la ventana principal.
Postcondiciones	• El usuario queda autenticado con su token de Windows. • El ingreso queda en la bitácora.

Elemento	Descripción
Flujos alternativos	4.1 Credenciales incorrectas: el sistema muestra un mensaje genérico y suma un intento fallido. Al quinto fallo en 10 minutos, la cuenta se bloquea 15 minutos (`CuentaBloqueada`). 4.2 Contraseña temporal: el sistema pide crear una contraseña nueva antes de continuar. 5.1 Cuenta ajena a Custodia: se rechaza el ingreso aunque la contraseña sea correcta. 6.1 Código incorrecto o ya usado: se rechaza y cuenta para el bloqueo.

Nota. Descripción del caso de uso iniciar sesión. Elaboración propia.

Tabla 7
Caso de uso explorar y abrir archivos

Elemento	Descripción
Caso de uso	Explorar y abrir archivos
Identificador	CU-02
Descripción	Permite listar, buscar y abrir los archivos de las carpetas a las que el usuario tiene acceso.
Actor principal	Usuario estándar
Actor secundario	Windows
Precondiciones	• El usuario inició sesión.
Flujo principal	1. El usuario elige una carpeta en el panel «Carpetas». 2. El sistema adopta la identidad del usuario y lista la carpeta; Windows decide qué puede ver. 3. El usuario selecciona un archivo y lo abre. 4. El sistema lee el archivo con la identidad del usuario, lo descifra y verifica su etiqueta de autenticación. 5. El sistema revierte la identidad en un bloque `finally`.
Postcondiciones	• El usuario ve el contenido; la identidad de la aplicación queda restaurada.
Flujos alternativos	2.1 Sin permiso: Windows deniega el acceso y el sistema muestra el error (`PermissionDenied`); el intento queda en la bitácora. 4.1 Archivo alterado: la etiqueta GCM no coincide y el sistema rechaza el archivo (`CryptoError`).

Nota. Descripción del caso de uso explorar y abrir archivos. Elaboración propia.

Tabla 8
Caso de uso añadir archivos y carpetas

Elemento	Descripción
Caso de uso	Añadir archivos y carpetas
Identificador	CU-03
Descripción	Permite guardar archivos cifrados o crear carpetas en una ubicación del almacén.
Actor principal	Usuario estándar
Actor secundario	Windows, App de autenticación
Precondiciones	• El usuario inició sesión y tiene la verificación en dos pasos activa.

Elemento	Descripción
Flujo principal	1. El usuario pulsa «Añadir archivos» o arrastra archivos a la ventana. 2. El sistema pide un código TOTP y el usuario lo escribe. 3. El sistema valida el nombre y confina la ruta al almacén. 4. El sistema cifra el contenido y lo escribe de forma atómica con la identidad del usuario.
Postcondiciones	• El archivo queda cifrado en el almacén. • La operación queda en la bitácora.
Flujos alternativos	2.1 Sin verificación en dos pasos: el sistema ofrece activarla. 3.1 Nombre reservado, flujo alternativo o ruta fuera del almacén: se rechaza (`InvalidPathName`, `PathOutsideJail`). 4.1 Sin permiso de escritura: Windows deniega la operación y no queda ningún archivo parcial. 4.2 Archivo mayor de 64 MB: se rechaza (`FileTooLarge`).

Nota. Descripción del caso de uso añadir archivos y carpetas. Elaboración propia.

Tabla 9
Caso de uso renombrar o eliminar

Elemento	Descripción
Caso de uso	Renombrar o eliminar
Identificador	CU-04
Descripción	Permite cambiar el nombre o eliminar un archivo o carpeta.
Actor principal	Usuario estándar
Actor secundario	Windows, App de autenticación
Precondiciones	• El usuario inició sesión y tiene la verificación en dos pasos activa.
Flujo principal	1. El usuario selecciona el elemento y pulsa «Renombrar…» o «Eliminar». 2. El sistema pide un código TOTP y el usuario lo escribe. 3. El sistema ejecuta la operación con la identidad del usuario.
Postcondiciones	• El elemento queda renombrado o eliminado. • La operación queda en la bitácora.
Flujos alternativos	1.1 Espacio personal o carpeta compartida: no se pueden renombrar ni eliminar. 3.1 Sin permiso: Windows deniega la operación (`PermissionDenied`). 3.2 Ya existe un elemento con ese nombre: se rechaza (`AlreadyExists`).

Nota. Descripción del caso de uso renombrar o eliminar. Elaboración propia.

Tabla 10
Caso de uso guardar una copia

Elemento	Descripción
Caso de uso	Guardar una copia
Identificador	CU-05
Descripción	Permite exportar una copia legible de un archivo fuera del almacén.
Actor principal	Usuario estándar
Actor secundario	Windows, App de autenticación

Elemento	Descripción
Precondiciones	• El usuario puede leer el archivo y tiene la verificación en dos pasos activa.
Flujo principal	1. El usuario selecciona el archivo y pulsa «Guardar una copia…». 2. El sistema pide el motivo de la copia. 3. El sistema pide un código TOTP y el usuario lo escribe. 4. El sistema descifra el archivo con la identidad del usuario y guarda la copia donde se eligió.
Postcondiciones	• La copia queda fuera del almacén, sin cifrar. • La copia y su motivo quedan en la bitácora.
Flujos alternativos	4.1 Más de 20 copias en 10 minutos: el sistema bloquea nuevas copias durante 15 minutos. 4.2 Sin permiso de lectura: Windows deniega la operación.

Nota. Descripción del caso de uso guardar una copia. Elaboración propia.

Tabla 11
Caso de uso gestionar permisos

Elemento	Descripción
Caso de uso	Gestionar permisos
Identificador	CU-06
Descripción	Permite consultar quién tiene acceso a un elemento y conceder o quitar permisos NTFS.
Actor principal	Usuario estándar
Actor secundario	Administrador, Windows
Precondiciones	• El usuario es administrador o dueño del elemento y tiene la verificación en dos pasos activa.
Flujo principal	1. El usuario selecciona un elemento y pulsa «Permisos…». 2. El sistema muestra las entradas de la ACL, marcando las heredadas y las denegadas. 3. El usuario elige a quién, qué puede hacer y si se aplica a lo que contenga, y pulsa «Conceder». 4. El sistema pide un código TOTP. 5. El sistema escribe la ACL con la identidad del usuario.
Postcondiciones	• La ACL queda actualizada y se puede comprobar con `icacls`. • El cambio queda en la bitácora.
Flujos alternativos	5.1 Sin el derecho `WRITE_DAC`: Windows deniega el cambio (`PermissionDenied`). 2.1 Entradas heredadas: no se editan aquí; se cambian en la carpeta superior.

Nota. Descripción del caso de uso gestionar permisos. Elaboración propia.

Tabla 12
Caso de uso activar verificación en dos pasos

Elemento	Descripción
Caso de uso	Activar verificación en dos pasos
Identificador	CU-07
Descripción	Permite al usuario dar de alta su segundo factor TOTP.

Elemento	Descripción
Actor principal	Usuario estándar
Actor secundario	App de autenticación
Precondiciones	• El usuario inició sesión.
Flujo principal	1. El usuario abre su perfil > «Verificación en dos pasos» y pulsa «Activar». 2. El sistema genera un secreto y muestra un código QR. 3. El usuario escanea el código con la aplicación de su teléfono. 4. El usuario escribe el código que muestra la aplicación y pulsa «Confirmar y activar». 5. El sistema guarda el secreto protegido con DPAPI.
Postcondiciones	• Desde el siguiente ingreso se pide el código, y también en cada operación sensible.
Flujos alternativos	4.1 Código incorrecto: el sistema no activa el segundo factor. Pérdida del teléfono: un administrador restablece el segundo factor desde «Cuentas y grupos».

Nota. Descripción del caso de uso activar verificación en dos pasos. Elaboración propia.

Tabla 13
Caso de uso cambiar contraseña

Elemento	Descripción
Caso de uso	Cambiar contraseña
Identificador	CU-08
Descripción	Permite al usuario cambiar su contraseña de Windows desde la aplicación.
Actor principal	Usuario estándar
Actor secundario	Windows
Precondiciones	• El usuario inició sesión o entró con una contraseña temporal.
Flujo principal	1. El usuario abre su perfil > «Contraseña» > «Cambiar mi contraseña». 2. Escribe la contraseña actual y la nueva dos veces. 3. El sistema valida la regla (al menos 8 caracteres, con letras y números) y Windows cambia la contraseña.
Postcondiciones	• La contraseña cambia también para entrar al equipo. • Con el cifrado por usuario activo, la clave privada queda protegida con la nueva contraseña.
Flujos alternativos	3.1 Contraseña actual incorrecta: se rechaza y cuenta para el bloqueo. 3.2 Contraseña nueva que no cumple la regla: el sistema no permite continuar.

Nota. Descripción del caso de uso cambiar contraseña. Elaboración propia.

Tabla 14
Caso de uso bloquear y desbloquear la sesión

Elemento	Descripción
Caso de uso	Bloquear y desbloquear la sesión
Identificador	CU-09
Descripción	Protege una sesión desatendida.

Elemento	Descripción
Actor principal	Usuario estándar
Actor secundario	—
Precondiciones	• El usuario inició sesión.
Flujo principal	1. Tras 5 minutos sin uso, o con Ctrl+L, el sistema cubre la ventana con la pantalla de bloqueo. 2. El usuario escribe su contraseña y pulsa «Desbloquear».
Postcondiciones	• La sesión continúa donde estaba.
Flujos alternativos	2.1 Pasan 30 minutos más sin desbloquear: el sistema cierra la sesión y libera el token. 2.2 El usuario pulsa «Cerrar sesión»: vuelve a la pantalla de inicio.

Nota. Descripción del caso de uso bloquear y desbloquear la sesión. Elaboración propia.

Tabla 15
Caso de uso administrar cuentas y grupos

Elemento	Descripción
Caso de uso	Administrar cuentas y grupos
Identificador	CU-10
Descripción	Permite crear, incorporar, retirar o eliminar cuentas, gestionar grupos y restablecer contraseñas o el segundo factor.
Actor principal	Administrador
Actor secundario	Windows, App de autenticación
Precondiciones	• El administrador tiene la verificación en dos pasos activa.
Flujo principal	1. El administrador abre su perfil > «Cuentas y grupos». 2. Elige «Cuenta nueva», «Añadir una cuenta de Windows existente», «Nuevo grupo» o una acción sobre una cuenta. 3. Confirma con su código TOTP. 4. El sistema aplica el cambio en las cuentas locales de Windows; al restablecer una contraseña, muestra una sola vez la contraseña temporal.
Postcondiciones	• La cuenta o el grupo quedan actualizados en Windows. • La acción queda en la bitácora.
Flujos alternativos	2.1 Cuenta que no pertenece a Custodia o cuenta integrada de Windows: el sistema no la modifica (`ProtectedAccount`). 2.2 Retirar al último administrador o a uno mismo: se rechaza. 2.3 Cuenta que ya existía en Windows: solo se puede «Retirar de Custodia», no eliminar.

Nota. Descripción del caso de uso administrar cuentas y grupos. Elaboración propia.

Tabla 16
Caso de uso consultar y verificar la bitácora

Elemento	Descripción
Caso de uso	Consultar y verificar la bitácora
Identificador	CU-11
Descripción	Permite revisar los eventos registrados y comprobar que la bitácora no fue alterada.

Elemento	Descripción
Actor principal	Administrador
Actor secundario	Windows
Precondiciones	• El usuario es administrador de Custodia.
Flujo principal	1. El administrador abre su perfil > «Bitácora». 2. Filtra por usuario, operación, fecha o resultado (Todos, Denegados, Permitidos). 3. Elige un evento para ver todos sus datos. 4. Pulsa «Verificar integridad». 5. El sistema recorre la cadena de registros y la compara con las anclas del Visor de eventos.
Postcondiciones	• El sistema indica si la cadena está íntegra. • La verificación queda en la bitácora.
Flujos alternativos	5.1 Cadena rota: el sistema indica el primer registro afectado y si fue editado, borrado, insertado o truncado. 5.2 Visor de eventos sin anclas o inaccesible: el sistema avisa, pero verifica la cadena.

Nota. Descripción del caso de uso consultar y verificar la bitácora. Elaboración propia.

Tabla 17
Caso de uso respaldar y restaurar la clave maestra

Elemento	Descripción
Caso de uso	Respaldar y restaurar la clave maestra
Identificador	CU-12
Descripción	Permite exportar la clave maestra cifrada con una contraseña de recuperación y restaurarla, incluso en otro equipo.
Actor principal	Administrador
Actor secundario	App de autenticación
Precondiciones	• El administrador tiene la verificación en dos pasos activa.
Flujo principal	1. El administrador abre su perfil > «Respaldo de la clave». 2. Para exportar, elige «Exportar respaldo», escribe dos veces una contraseña de al menos 12 caracteres, elige el destino y confirma con su código. 3. Para restaurar, elige «Restaurar respaldo», el archivo `.custodiakey` y su contraseña, y confirma con su código. 4. Antes de instalar la clave restaurada, el sistema comprueba que abra los archivos del almacén.
Postcondiciones	• Al exportar, queda un archivo `.custodiakey` de 88 bytes cifrado con scrypt y AES-256-GCM. • Al restaurar, la clave anterior se conserva 30 días.
Flujos alternativos	2.1 Destino dentro del almacén o junto a la clave: se rechaza. 3.1 Contraseña incorrecta o archivo alterado: no se instala nada (`RespaldoError`). 4.1 La clave no abre los archivos del almacén: no se instala.

Nota. Descripción del caso de uso respaldar y restaurar la clave maestra. Elaboración propia.

Tabla 18
Caso de uso crear clave de recuperación y recuperar una cuenta

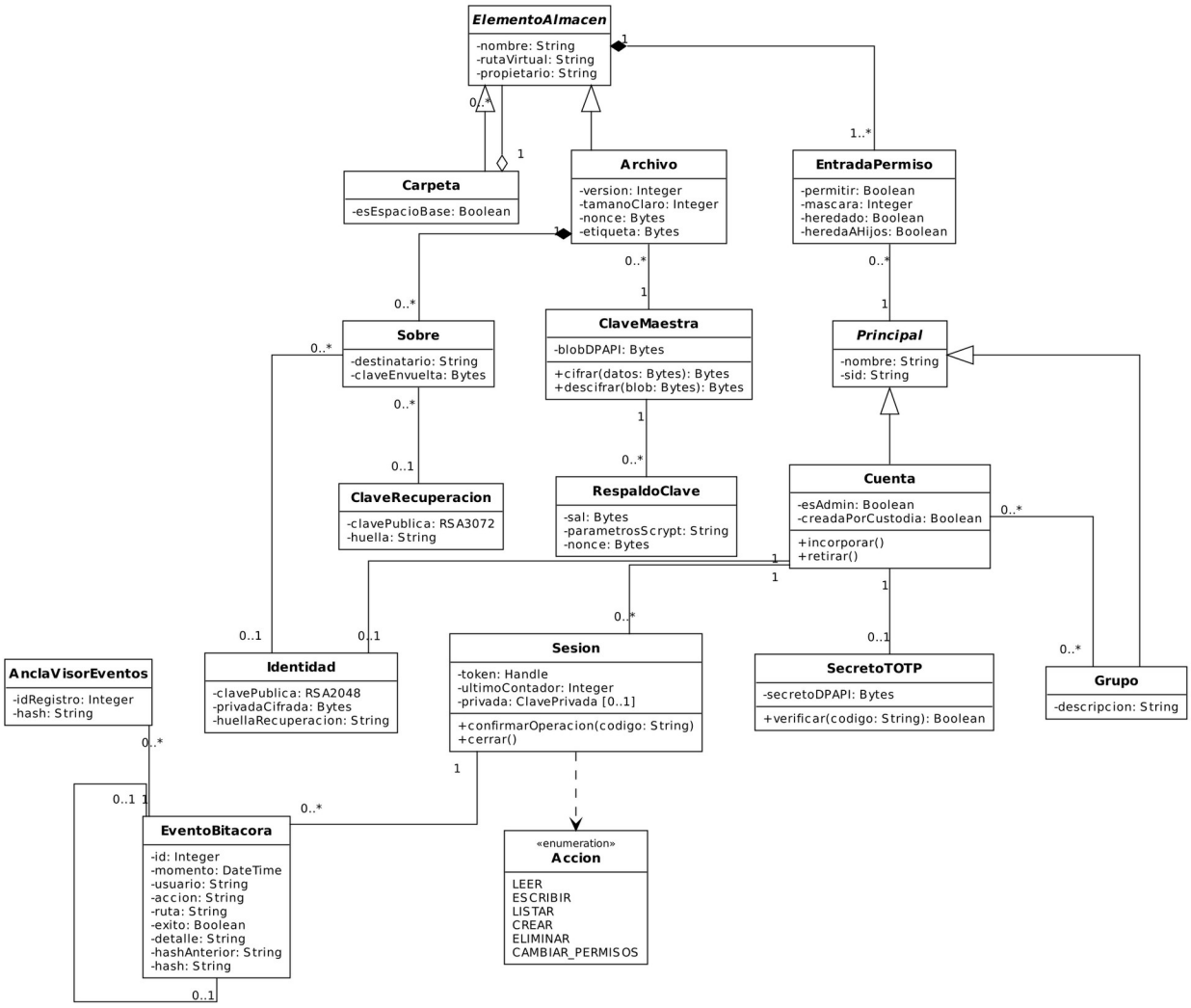
Elemento	Descripción
Caso de uso	Crear clave de recuperación y recuperar una cuenta
Identificador	CU-13
Descripción	Permite habilitar el cifrado por usuario sin riesgo de perder archivos, y devolver sus archivos a quien olvidó la contraseña.
Actor principal	Administrador
Actor secundario	App de autenticación
Precondiciones	• El administrador tiene la verificación en dos pasos activa.
Flujo principal	1. El administrador abre «Respaldo de la clave» > «Crear clave de recuperación». 2. Escribe dos veces una contraseña de al menos 12 caracteres, distinta de la del respaldo, y elige una USB como destino. 3. El sistema genera un par RSA-3072, guarda la privada cifrada en el archivo `.custodiarec` y registra la pública en el equipo. 4. Para recuperar, elige «Recuperar archivos de una cuenta», el archivo de la USB, su contraseña y la cuenta.
Postcondiciones	• Cada archivo cifrado por usuario lleva un sobre para la clave de recuperación. • Al recuperar, la persona vuelve a poder abrir sus archivos.
Flujos alternativos	1.1 Ya existe una clave de recuperación: no se puede crear otra. 4.1 Clave de recuperación sustituida en el equipo: el sistema falla cerrado (`IdentidadAlterada`).

Nota. Descripción del caso de uso crear clave de recuperación y recuperar una cuenta. Elaboración propia.

Modelo de datos

Custodia no tiene una base de datos de usuarios ni de permisos: las cuentas y las contraseñas las guarda Windows en la SAM, los permisos están en las ACL de NTFS y los archivos son archivos reales del almacén. La única base de datos es la bitácora de auditoría. La Figura 2 presenta el diagrama de clases del dominio: `Cuenta` y `Grupo` son cuentas y grupos locales de Windows, `EntradaPermiso` es una entrada de la ACL de NTFS, y un `Archivo` se cifra con la `ClaveMaestra` (versión 1) o lleva un `Sobre` por cada persona autorizada y por la `ClaveRecuperacion` (versión 3). La Tabla 19 describe la tabla de la bitácora y la Tabla 20 los archivos de datos del sistema.

Figura 2
Diagrama de clases



Nota. Elaboración propia.

Tabla 19
Diccionario de datos de la bitácora (tabla eventos)

Columna	Tipo	Descripción
id	INTEGER	Clave primaria autoincremental; forma parte del resumen del registro.
momento	TEXT	Fecha y hora en UTC, en formato ISO 8601.
usuario	TEXT	Cuenta de Windows que hizo la operación (la identidad efectiva del hilo).
accion	TEXT	Tipo de operación: ingreso, lectura, escritura, cambio de permisos, copia, etc.
ruta	TEXT	Recurso sobre el que se actuó, como ruta virtual del almacén.
exito	INTEGER	1 si se permitió, 0 si se denegó o falló.

Columna	Tipo	Descripción
detalle	TEXT	Información adicional, como el motivo de una copia (hasta 1000 caracteres).
hash_anterior	TEXT	SHA-256 del registro anterior; el primero usa un valor génesis de ceros.
hash	TEXT	SHA-256 del contenido del registro y de `hash_anterior`.

Nota. Elaboración propia a partir del módulo `audit.py`. Índices sobre `momento` y `usuario`.

Tabla 20
Archivos de datos del sistema

Archivo o carpeta	Contenido	Protección
storage\	Almacén: carpeta personal de cada usuario y carpeta `Compartida`.	ACL de NTFS; contenido cifrado.
audit.db	Bitácora de auditoría (SQLite).	ACL que excluye a los usuarios estándar.
master.key	Clave maestra AES-256.	DPAPI y ACL de Administradores y SYSTEM.
master.key.anterior-<fecha>	Copia de la clave anterior tras restaurar un respaldo (30 días).	DPAPI y ACL.
2fa.dat	Secretos TOTP de cada usuario.	DPAPI y ACL.
intentos.dat	Intentos fallidos para el bloqueo.	ACL.
descargas.dat	Conteo de copias por usuario.	ACL.
identidades.json	Pares de claves del cifrado por usuario y clave pública de recuperación.	Privadas cifradas con scrypt; ACL.

Nota. Todos los archivos están en `C:\ProgramData\Custodia`. Elaboración propia a partir del módulo `config.py`.

Cada archivo del almacén se guarda con el formato de la Tabla 21. Los primeros 29 bytes son comunes a las dos versiones, lo que permite listar el tamaño real sin descifrar.

Tabla 21
Formato de un archivo cifrado

Campo	Tamaño	Descripción
Marca	8 bytes	Texto `CUSTODIA`.
Versión	1 byte	1 = clave maestra; 3 = cifrado por usuario.
Tamaño original	8 bytes	Tamaño del contenido sin cifrar.
Nonce	12 bytes	Número aleatorio de 96 bits, nuevo en cada escritura.
Sobres (solo versión 3)	Variable	Clave del archivo envuelta con RSA-OAEP para cada persona autorizada y para la clave de recuperación.

Campo	Tamaño	Descripción
Contenido y etiqueta	n + 16 bytes	Contenido cifrado con AES-256-GCM y etiqueta de autenticación de 128 bits.

Nota. Elaboración propia a partir de los módulos `crypto.py` y `boveda.py`.

Seguridad y control de operación

La seguridad de Custodia está construida en capas, de modo que cada una cubre lo que la anterior no alcanza:

- **Autorización.** La aplicación no evalúa permisos: cada operación se ejecuta con la identidad del usuario y la autoriza el núcleo de Windows según la ACL de NTFS. La suplantación se concentra en la clase `Sesion` y se revierte siempre en un bloque `finally`.
- **Autenticación.** Las contraseñas las valida Windows; Custodia no guarda ninguna. Después de cinco intentos fallidos en diez minutos la cuenta se bloquea 15 minutos. El segundo factor TOTP se pide al entrar y en cada operación sensible, y cada código sirve una sola vez.
- **Mínimo privilegio.** La raíz del almacén solo se puede atravesar, cada espacio personal tiene la herencia rota y la carpeta compartida se concede al grupo. Toda ruta se confina al almacén.
- **Confidencialidad.** Cada archivo se cifra con AES-256-GCM. La clave maestra está protegida con DPAPI y solo existe en claro en memoria. Con el cifrado por usuario, ni un administrador sin la contraseña del dueño puede leer los archivos personales.
- **Integridad.** La etiqueta GCM detecta cualquier alteración de un archivo, y las escrituras son atómicas: una operación fallida no deja archivos parciales.
- **Trazabilidad.** La bitácora la escribe un hilo que nunca suplanta, y cada registro guarda el resumen del anterior. Cada 50 eventos y al cerrar, el último resumen se ancla en el Visor de eventos de Windows (origen `Custodia`).

- **Disponibilidad.** La clave maestra se respalda cifrada en una USB y se puede restaurar en otro equipo, comprobando antes que abra los archivos.
- **Volumen.** Al iniciar se comprueba si BitLocker protege la unidad del almacén; si no, se registra y se avisa, y con `CUSTODIA_EXIGIR_BITLOCKER=1` no se deja entrar.

Cuando una operación no cumple una regla, el sistema la rechaza completa y muestra un mensaje. La Tabla 22 lista los errores del núcleo que puede encontrar el administrador.

Tabla 22
Errores del sistema

Error	Significado
AuthenticationError	Usuario o contraseña incorrectos, o cuenta deshabilitada.
CuentaBloqueada	Cuenta bloqueada temporalmente por demasiados intentos fallidos.
SegundoFactorRequerido	La operación exige un código TOTP válido.
CambioDeContrasenaRequerido	La cuenta entró con una contraseña temporal y debe cambiarla.
SessionError	Sesión inexistente, expirada o cerrada.
PermissionDenied	Windows denegó la operación según la ACL de NTFS.
PathOutsideJail	La ruta se sale del almacén.
InvalidPathName	Nombre no válido para Windows: caracteres prohibidos, flujo alternativo o nombre reservado.
NotFound / AlreadyExists	El elemento no existe, o ya existe uno con ese nombre.
FileTooLarge	El archivo supera el tamaño máximo.
AccountError / ProtectedAccount	Error al administrar una cuenta o grupo, o intento de modificar una cuenta que no pertenece a Custodia o es integrada de Windows.
CryptoError	No se pudo cifrar o descifrar: archivo alterado o clave no disponible.
IdentidadAlterada	La clave pública de una identidad o la de recuperación fueron sustituidas; el sistema falla cerrado.
RespaldoError	Contraseña de respaldo incorrecta, archivo alterado o destino no permitido.

Nota. Elaboración propia a partir del módulo `errors.py` (Aranguren y Quintana, 2026a).

Recomendaciones de operación

- Exportar el respaldo de la clave maestra apenas se instale Custodia y después de restaurarla, guardar el archivo y su contraseña en lugares distintos, y probar la restauración en un segundo equipo (Barker, 2020).

- Activar BitLocker con TPM en el equipo y definir `CUSTODIA_EXIGIR_BITLOCKER=1`, para cubrir el robo del disco completo.
- Crear la clave de recuperación y activar el cifrado por usuario; la USB con el archivo `.custodiarec` la conserva el dueño del computador, desconectada.
- Verificar la integridad de la bitácora periódicamente, dar al registro Application del Visor de eventos un tamaño suficiente para conservar las anclas y mantener sincronizado el reloj del equipo.
- Copiar con regularidad la carpeta `C:\ProgramData\Custodia\storage` a un medio externo: los archivos se copian cifrados.
- Revisar las cuentas de `Custodia_Usuarios` y retirar las que ya no se usan.

Referencias

Aranguren, D. Y., y Quintana, P. A. (2026a). *Custodia: código fuente* [Repositorio]. GitHub. https://github.com/yanni2327/custodia

Aranguren, D. Y., y Quintana, P. A. (2026b). *Custodia: aplicación de escritorio para la custodia cifrada de archivos con control de acceso real sobre Windows* [Informe final no publicado]. Universidad Cooperativa de Colombia, Campus Villavicencio.

Barker, E. (2020). *Recommendation for key management: Part 1 – General* (NIST Special Publication 800-57 Part 1 Rev. 5). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-57pt1r5

M'Raihi, D., Machani, S., Pei, M., y Rydell, J. (2011). *TOTP: Time-based one-time password algorithm* (RFC 6238). Internet Engineering Task Force. https://doi.org/10.17487/RFC6238

Microsoft. (s.f.-a). *Access control lists*. Microsoft Learn. https://learn.microsoft.com/windows/win32/secauthz/access-control-lists

Microsoft. (s.f.-b). *CryptProtectData function (dpapi.h)*. Microsoft Learn. https://learn.microsoft.com/windows/win32/api/dpapi/nf-dpapi-cryptprotectdata

Microsoft. (s.f.-c). *ImpersonateLoggedOnUser function (securitybaseapi.h)*. Microsoft Learn. https://learn.microsoft.com/windows/win32/api/securitybaseapi/nf-securitybaseapi-impersonateloggedonuser

PyInstaller Development Team. (s.f.). *PyInstaller manual*. https://pyinstaller.org

Schneier, B., y Kelsey, J. (1999). Secure audit logs to support computer forensics. *ACM Transactions on Information and System Security, 2*(2), 159–176. https://doi.org/10.1145/317087.317089